BSc Hons in Computing

2024.2

Cyber Security

Course Work

Coventry Index: 16114667

NIBM Index: CobscComp24.2p-048

NIBM Registered Name: M. H. T. U. D. Silva

Faculty of Engineering, Environment and Computing School of Computing, Electronics and Mathematics Coventry University

School of Computing and Engineering National Institute of Business Management

Table of Contents

PART A 1

A1. Context 1

Business Purpose 1

Critical Assets 3

Primary Roles 4

Key Integrations 5

A2. Architecture Diagram 6

A3. Key Risks 7

A4. Mini SRS 8

PART – B 11

B1. Target Environment and Shared Responsibility 11

Target Environment 11

Shared Responsibilities 11

B2. Identity, Authn/z, and Secrets 14

Identity 14

Authentication (AuthN) 14

Authorization (AuthZ) 15

Secrets 16

B3. Network and Platform Security 17

Network security 17

Platform Security 20

B4. Application Security Engineering 21

B5. Data protection 24

B6. Observability, detection & response 26

Observability 26
Detection 27
Response 28
B7. Resilience and Reliability 29
B8. Compliance, Privacy and Audit 31
Compliance 31
Privacy 31
Audit 31
B9. Traceability to SRS 32
References 35

PART A

A1. Context

Business Purpose

For the project, I have chosen the People's Bank Online Banking System.

- Industry: Banking
- System: People's Bank Online Banking System

The People's Bank Online Banking System introduced to their customers to provide the banking services online with high security to enables retail and business customers to perform everyday banking tasks without visiting a branch. This online banking system consists of both web and mobile applications for customers.

The People's Bank Online Banking system revolves around three main applications;

→ People's Pay: Mobile wallet application for sending money, paying merchants, and QR payments.

→ People's Wave: Mobile banking application for personal banking operations like accounts, transfer, bills, and cards

→ Internet Banking: The web portal for browser based banking operations.

The three main parts of the system:

1. User Interface (frontend): This is Client layer of the system. The purpose of this is to let user securely interact with the banking system.

Mobile Application (Android/iOS)	Web portal
• Login • Password/Pin • Biometrics • Transfer UIs • Payments UIs • Transaction confirms screens • QR scanner	• Login • Password/Pin • *(No biometrics available)* • Transfer UIs • Payments UIs • Transaction confirms screens • *(No QR scanner available)*

2. Server logic (backend): This is the Application Layer of the system. It allows process requests securely while applying business rules and banking logics. This is consists of API gateways and application servers

3. Database (storage): This is the Data Layer of the system. Here the purposes is to keep personal identifiable information(PII) and sensitive financial data secure, accurate and available.
    - Customer details
    - Account balance
    - Transaction history
    - Card Information
    - Loan details
    - Login logs/ device logs
    - Audit trails.

Critical Assets

1. User Credentials
    - ID
    - Password
2. Authentication Factors
    - Biometrics Identifiers
    - Multi Factor Access tokens
    - Device Bindings
3. Account Details and Transaction Details
    - Account Balance
    - Transaction History
    - Standing Orders
4. Personal Identifiable Information (PII)
    - NIC number
    - Contact Details
    - PANs (Primary Account Number)
    - Account Number
5. Application Secrets and Cryptographic Keys
    - Database Credentials
    - API keys
    - HSM(Hardware Security Module) managed Root keys
    - KMS(Key Management System) managed Root keys
    - TLS Certificates
6. External integration credentials
    - LankaPay/CEFT Credentials
    - API keys for Billers
    - Card Networks

7. Audit Logs and Security Logs
    - Compliance
    - Dispute Resolutions(Solving customer problems with transactions)
8. Backups and DR(Disaster Recovery) artifacts
    - Encrypted snapshots
    - Off-site backups
9. Operational Infrastructure
    - Network Devices
    - WAF(Web Application Firewall)
    - SIEM()
    - Admin Console

Primary Roles

The two main types of users with different permissions;

1. Customers(Web users, and Mobile users): External users.
2. Admin(Bank staff who manage Online banking system): Internal users.

Key Integrations

1. SMS and email notification
2. SMS or OTP gateway
3. Card Management
4. QR Payment Network
5. Identity verification and KYC Provider
6. Fraud detection and Risk analytics
7. Loan Management system
8. LankaPay/CEFTs (interbank switch)
9. Utility and Bill Payment Aggregators
10. Core banking system (CBS)
11. Exchange Rate Provider
12. AML (Anti-Money Laundering) system
13. SIEM/ Audit logging system

The integrations into other external services are;

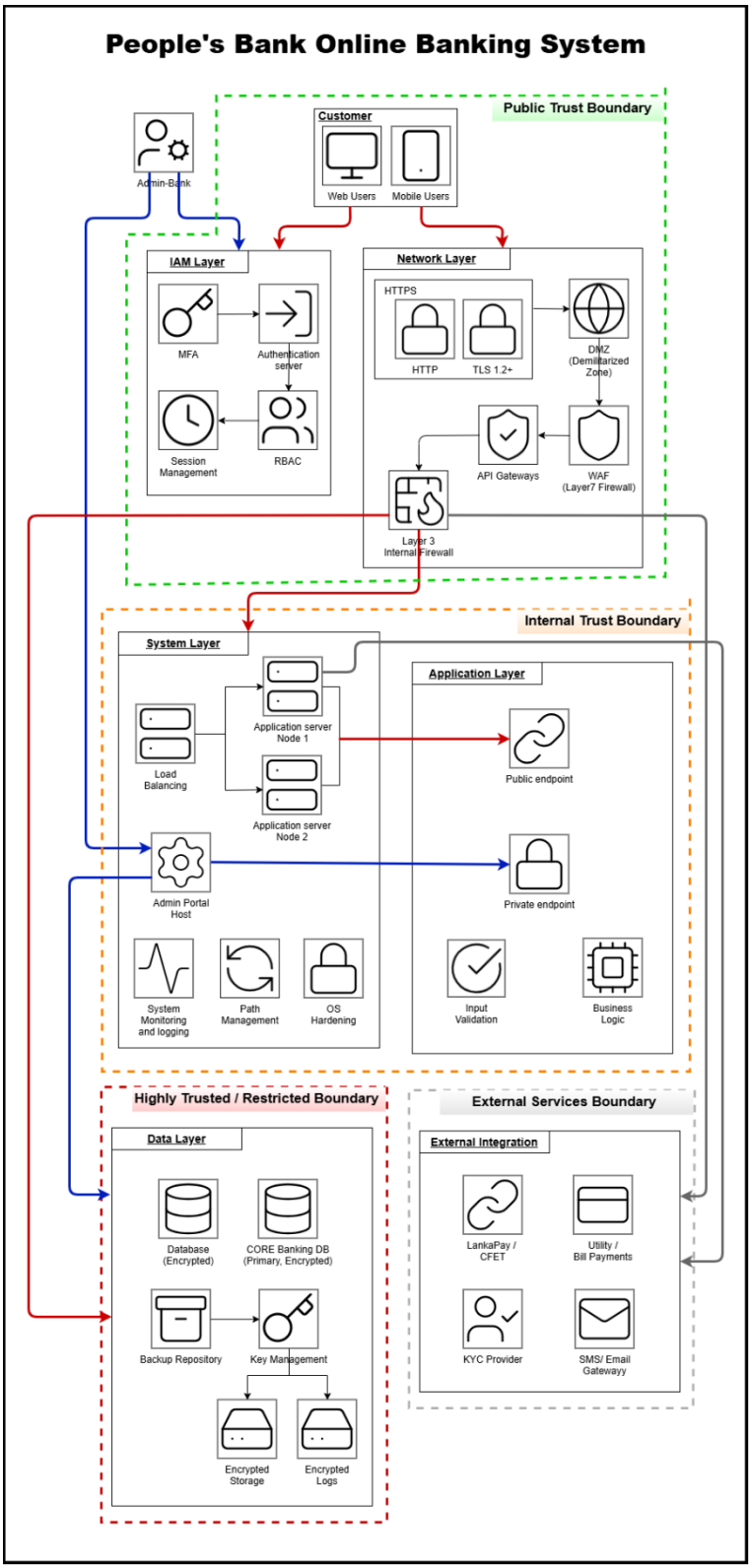
1. Interbank Transaction with LankaPay/ CEFT Switch

   This service allows users to do transactions between other banks. Without LankaPay, the People's bank online banking system could only be able provide transactions between only within the People's Bank accounts and users.
2. Utility and Bill payment providers

   This service is for letting customers pay their bills using application.

   Ex: CEB, LECO, SLT, Water Board and mobile bill payments or reloads.

A2. Architecture Diagram



A3. Key Risks

- Account takeover through phishing attacks, credential threats, social engineering.
- Data breaches
- Unauthorized or fraudulent transactions.
- PII or financial data theft.
- Compromise of APIs or third party integration.
- Insider misuse of privileged access threats.
- Malware/ Ransomware
- Privacy leaks
- DDoS attacks
- Backup or recovery failures

A4. Mini SRS

IAM Layer

1. ID: IAM-01

   Requirement: MFA for all users(both customer and admin).

   Acceptance Test:

- Login with username and only a password - Authentication must fail.
- Login with username and password + OTP/SMS/app token - Authentication must success.

2. ID: IAM-02

   Requirement: Role-based access.

   Acceptance Test:

   - Customer try */admin/** - System must denied the performance.
   - Admin try /transfer - System must denied the performance.

3. ID: IAM-03

   Requirement: Session Management.

   Acceptance Test:

   - Leave online banking system application idle for the configured time - System must logout the user automatically.
   - After a logout the reused session token - System must reject.

Network Layer

1. ID: NET-01

   Requirement: Database must not expose it any ports to the public.

   Acceptance Test:

   - Run a port scan from external network - DB ports must be closed or not visible.

2. ID: NET-02

   Requirement WAF + Rate limit.

   Acceptance Test:

   - Send many login attempts quickly like 20 login attempts in 5 seconds - WAF must rate limit or block.
   - Send SQLi payload - WAF must block the request.

3. ID: NET-03

   Requirement: Segmented network zones.

   Acceptance Test:

   - Try to reach the data layer directly from DMZ - Connection must fail.

System Layer

1. ID: SYS-01

   Requirements: Hardened servers.

   Acceptance Test:

   - Run CIS benchmark scan - No high severity failures allowed.

2. ID: SYS-02

   Requirements: Monitoring and logging.

   Acceptance Tests:

   - Trigger a failed login - The event must appears in SIEM within 30 seconds.
   - Modify a system file - Alert must appears in SIEM.

Application Layer

1. ID: APP-01

   Requirement: Input Validation and output encoding.

   Acceptance Tests:

   - Submit invalid payloads - API must reject and return 400 error or a validation error.

2. ID: APP-02

   Requirement: Secrets from secure vault.

   Acceptance Tests:

   - Inspect code repo - No secret found.
   - View and check logs - No secret printed.

Data Layer

1. DATA-01

   Requirement: Encryption at rest/in transit.

   Acceptance Test:

   - Disable encryption and attempt start - Database must not permit unencrypted mode.
   - Connect to databases without TLS - Connection must fail.

2. ID: DATA-02

   Requirement: Key Management/rotation.

   Acceptance Test:

   - Check KMS logs - Rotation events appear at required intervals.

3. ID: DATA-03

   Requirement: Backups and Restore testing.

   Acceptance Test:

   - Restore backup to test environment – Data must match production snapshot.
   - Backup files inspected – Must be encrypted.

PART – B

B1. Target Environment and Shared Responsibility

Target Environment

The people's Bank Online Banking System use hybrid environment which is combine with both Cloud and on-premises. This is a practical choice for most large size banks on today.

Cloud for handle the frontend and traffic management. In Cloud for;

- Web application frontend and Mobile Application gateways.
- Content Driver Network(CDN)
- WAF and DDoS protection
- Traffic routing and monitoring

On-premises for mange banking operations. In On-premises for;

- Core Banking services and application servers.
- Internal APIs and Internal service Bus
- Bank Account and transaction databases
- HSM modules for card, PIN operations

Shared Responsibilities

In the People's Bank Online Banking System, there are 3 types of shared responsibilities.

1. Shared Responsibility with Cloud provider and the Bank
2. Shared Responsibility with On-premise and the Bank
3. Shared Responsibility with Service provider and the Bank

Shared Responsibility with Cloud provider and the Bank

Cloud Provider Responsibility	**Bank Responsibility**
→ Maintain physical servers, network and cloud platform.	→ Provide secure frontend applications and API gateways.
→ Maintain Hardening OS level security → Apply patch management	→ Configure the WAF → Do TLS enforcements → Manage IAM/SAML policies
→ Provide CDN → Provide Traffic routing	→ Monitor traffic → Analyze logs → Respond to alerts
→ Offer DDoS Protection	→ Tuning DDoS/WAF → Enforce Access control

Shared Responsibility with On-premise and the Bank

On-premises Responsibility	**Bank Responsibility**
→ Provide servers, storage, network and physical security	→ Maintain core banking operations and databases
→ Backup infrastructure	→ Perform database backups → Implement DR(Disaster Recovery) tests
→ Ensure OS security and network security	→ Harden OS → Manage application patches and user access

Shared Responsibility with External Service Providers and the Bank

External Service Providers Responsibility	**Bank Responsibility**
→ Secure their APIs	→ Secure internal integrations and connections.
→ Ensure operating time and performance of services.	→ Validate and sanitize inputs and outputs → Monitor integration failures
→ Protect their infrastructures	→ Enforce TLS → Manage API keys → Maintain allow lists

B2. Identity, Authn/z, and Secrets

In this sector we talk about the security of identity and the access of both customer and admin users. This is one of the most critical parts in a banking system because system must provide strong protection for the both users as an online banking systems are working with people sensitive financial data.

Identity

Identity is the digital representation of the users in the inside of the system of banking platform;

- Pay ID: the Id that for customers.
- Account Number: Backend system connecting with a service account.
- For the amin login, staff with the privileges has specific staff ID.

Authentication (AuthN)

In here, Authentication part applys separately to customers and admins.

1. **Customer Authentication;**
    - Customer accounts need to enable the 2FA (2-Factor Authentication)/MFA.
    - Customer accounts basically login through a password and optional biometric identifier. But this biometric feature only applies for mobile users.
    - For the sensitive actions like fund transactions, adding payees, changing profile information system use mandatory MFA or OTP.
    - The session token stored in secure cookies.
    - System automatically logout the users after five minutes of inactivate.

2. **Admin Authentication;**

   Here, the admin accounts are more privileged than customer accounts. So, the Admin Authentication is a high security zone which requires strong controls.

   - Admin accounts do authenticate via VPN and with MFA(TOTP)
   - The admin accounts also must enable the MFA/2FA authentication.
   - For access are allowed only from bank-issued devices and those devices are verified through endpoint certificates.
   - Here, in admin accounts the password only login are not allowed.

Authorization (AuthZ)

In here, in the Authorization part system use RBAC model (Role-based Access Control).

Customer Roles

1. Regular Customers
   - View account balances
   - View transaction history
   - Make fund transfers
   - Pay bills
   - Make QR payments
   - Update personal information
2. People's Bank staff as customers
   - Except do transaction between two staff-customers accounts from online banking system, they have all the permissions that a regular customer has.

Administration Roles

1. System Administrator: Manage configs
2. Fraud Analyst: Monitor suspicious activity
3. Customer Support Officer: They have limited view only access
4. Audit Officer: View logs and reports, Generate reports.

Secrets

What are mean by secrets?

- Passwords for database APIs and other services.
- The API keys and tokens that used for access external services.
- Encryption keys
- TLS/SSL certificates
- OAuth or Authentication tokens

→ All the secrets of the system stored in Vault/HSM but do not stored in config files.

→ These secrets are automatically change every 90 days.

→ TLS certificates are maintain through bank own certificate system.

→ Database credentials are stored in vault and fetched at runtime.

B3. Network and Platform Security

Network security

As the People's Bank Online Banking system use hybrid model architecture, it uses a layered and well segmented network. And these layers protect the system from the external attacks by using multiple security barriers.

Demilitarized Zone (DMZ) Segmentation

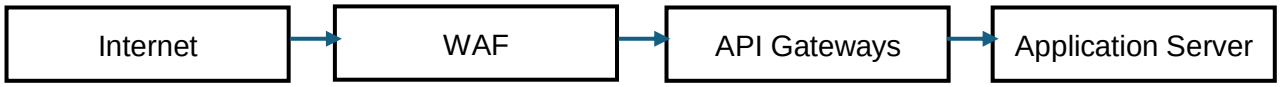
In here, the DMZ is a special network zone that plays as a bridge between the public internet and the bank internal network. DMZ makes sure that the public traffic is never touch the sensitive systems directly.

In segmentation here, means separating DMZ from the bank internal network and other zones.

In the DMZ has only the systems that are require to interact with the internet.

- WAF: To check the every request for attacks like SQL injection, bots, brute force etc.
- API Gateway: Take controls of which APIs are exposed, apply rate limits, authentication etc.
- DDoS Protection: This protects the system from the attacks where the huge amount of traffic try to overload the system.
- Load Balancer: Here, send incoming traffics to healthy servers, so the system does not crash.

The Traffic flow is;



Layer 3 Firewall Rules

The layer 3 firewall rules are decide what traffic is allowed into the network based on its IP addresses, source, destination, and protocols like TCP, UDP. This is help to stop the attackers from targeting on sensitive services directly.

Rules of the Layer 3 Firewalls are;

- Only port 443 (HTTPS) is allowed from the internet: This is to ensures only secure web traffic is enter to the system.
- Databases cannot be access directly from the DMZ or the internet. Because even if a hacker knows database server IP, they cannot reach the database from outside.
- Only the approved office, devices or VPN IP addresses can be access to the system from admin side of the system.

Transport Layer Security(TLS) Everywhere

As TLS is the encryption protocol that secure the data in the transit between client and server. So here, TLS everywhere means all the communications, internal and external services are encrypted using the TLS. This is help the bank to prevent from the attacks like eavesdropping, tampering etc.

In here;

- TLS 1.2+ enforce between the all service to service communications.
- Use the mutual TLS(mTLS) for admin and sensitive service calls initially.

Internal Network Segmentation

Here, the network divide into different zones. Those zones are communicate only via strict firewall rules and they have zero trust principles.

- Application Zone: This is includes application servers.
- Database Zone: This zone includes databases and HSM.
- Integration Zone: This one is consist with external integrations like LankaPay/CEFT, KYC, bill APIs
- Admin Zone: The admin zone is for monitoring, SIEM, VPN, IAM

API Gateway Enforcement

The API Gateway protects the backend from the bad traffic and the attacks. It is a security safe guard sitting in front of the application that checks every request.

- Rate limiting: Here, it block too many requests from a one source to prevent from the attacks like brute-force.
- Authentication token validation: Here, it check every request from the users has a valid token.
- Threat Detection: Here, it spots the bots or the suspicious behavior before it breach the backend.
- IP filtering: Here, it filter the access by restricting the requests for sensitive areas by locations and IPs.

Platform Security

In here, the platform security ensures that the servers, OS and software running the applications are configured securely, monitored and protected from unauthorized access and attacks.

Server Hardening

- In here, all the servers are hardened according to the security CIS benchmark(Center for Internet security)
- Here, only the required services are installed and default accounts disable.

Monitoring and Logging

In the People's Bank online banking system**,** all the servers and the applications are monitored continuously. So, it helps to find security events like failed logins, file modifications, or unauthorized access trigger alerts in SIEM.

B4. Application Security Engineering

Usually the online banking platforms handles the highly sensitive financial data and personal information. Therefore the application layers on those platform must have strong defensive controls to prevent from attacks like common web vulnerabilities and need to ensure that the logic flow is secured. And also the Application layer needs to guarantee that only the trusted and validate requests are can be interact with the backend.

Secure Coding Practices

- The development team of the people's bank follows secure coding standards which are aligned with OWASP Top 10.
- Validate user inputs: Check whether that the user inputs are in the correct form to use them. But reject inputs if that it does not match the rules or the validation.
- Sanitize user inputs: Clean the data so it cannot be used for do harmful actions. Remove dangerous character like <,>,',” etc that could allow XSS or SQL injection.
- Here, use parameterized queries for databases instead of storing user inputs directly in the database.
- Encode outputs: When showing the user input on application interfaces make sure that the special characters are do not run as code. The web framework that use in development has built-in function to do this automatically.
- During the build process the development team run;
    - → SAST(Static Application Security Testing) to detect the insecure infections, vulnerable dependencies and coding flows before the development.
    - → DAST(Dynamic Application Security Testing) to investigate the running application for injection risks, session weakness and misconfiguration.

Endpoint Segregation

In here, endpoints are separated based on sensitivity.

1. Public Endpoints: for customer uses
    - */login*
    - */register*
    - */transfer*
    - */profile/update*
2. Private Endpoints: for internal and admin uses
    - */admin/**
    - */internal/lankapay-api*
    - */internal/billpayy-api*
    - */internal/reporting-api*

Secure Session Management

Here is to take care of if the attacker stole login token or the session from the user and take over the user account.

For that people's Bank Online banking system is use;

- Short-lived JWT tokens: These tokens are expire quickly and even if stolen attackers cannot work for long.
- Refresh token rotation: These tokens use to refresh the application. When it refreshed then the old one is invalid.
- Auto logout: If the user are inactivate for a while then system expire the session automatically.
- Invalidate tokens on suspicious activities: If the system found unusual or the suspicious action system blocks the session.
- CSRF tokens: These tokens are unique and secret tokens which help the system to generate unpredictable values to prevent from attckers

Testing and CI/CD Security

Here in the CI/CD pipeline it does;

- Scanning the dependency to checks that the libraries are safe and up to date.
- Image scanning container makes sure that the server images do not have vulnerabilities.
- Secrets detection ensures that no passwords or API keys has in the code by accidently.
- Here has signed build artifacts that confirms the code has not tampered.

The System use Penetration testing for check;

- Where the broken access controls are.
- Which attempts re try to privileges.
- What are the ways to bypass MFA.
- What are the logic mistakes in the payments.
- What are the race conditions in the transactions

B5. Data Protection

1. **Encryption at Rest**

   Protect the data that stored in the database.

   - Use TDE(Transparent Data Encryption) to encrypt the whole database.
   - Use Column Level Encryption for the highly sensitive fields like NIC, Card numbers, Account numbers which needs extra protection.
   - Use Account Number Masking method to show only a part of the number like account number, phone number.
   - Logs files are also stored in encrypted disk volumes.

2. **Encryption in Transit**

   Protect the data while moving between services.

   - Here, People's bank use TLS 1.2+ to encrypt all the traffic between web portals, mobile applications, APIs, and backend.
   - Use Mutual TLS(mTLS) for both clients and server and put extra security for admin and internal system.
   - Certificates are rotate or replaced every 6 months to reduce risks.

3. **Key Management and Rotation**

   Maintain the safety of the data storing and handling encryption keys.

   - Keys stored in secure hardware device (HSM) or in a secure key vault.
   - Use automatic rotations. The keys are expire and rotate automatically by the system
   - Use separate keys like different keys for encryption, signing, and TLS as if one is compromised then the others will not affect.

4. Backups and Recovery

- Daily incremental backups for save only the changes of the day.
- Do full backups weekly to complete the whole database backup.
- With Off-site DR location can store copies in another secure place.
- Do Integrity checks with SHA-256 which is use to confirm that the backups were not changed.
- Team tests quarterly restore drills/backups to ensure that the everything is working finely.

B6. Observability, Detection and Response

Observability

The online banking system observe the system activities with dashboard monitoring and logging.

- **SIEM Log Collection**

  In here, the system collect the important logs like;

  → Login attempts.

  → Failed transactions.

  → Admin users accesses.

  → Database queries

  → API errors

- **Monitoring Dashboards**

  With the dashboards, system observe real-time status of the applications. In this system, the dashboards show;

  → Uptime and the performances

  → How the users are behaving.

  → API error rates

  → Integration connectivity

  → Database replications and delays.

Detection

The detection part of the online banking system focuses on finding threats, attacks, frauds and harmful activities.

- **SIEM Alerting Rules**

  This part of the SIEM helps to trigger alerts when unusual or suspicious thing happens like;

  → When the fund transfers increase suddenly.

  → When the login attempts happen from a foreign location.

  → When admins accounts are activated after the business hours.

  → When there are multiple failed OTP attempts.

- **Intrusion Detection System(IDS)**

  IDS use to watches the network and it detect;

  → Abnormal patterns

  → Abnormal traffic

  → Suspicious inbound and outbound connections

- **Fraud Monitoring**

  In here, it detect the risky financial behaviors like;

  → Fast or repeated transfers.

  → When the device changed and high value transaction happened.

  → Abnormal user behaviors.

Response

- **Incident Response Proces**

  Below are the steps;

  1. Create the Alert.
  2. Containment: Here, it stop the damage like block the account, isolate the server.
  3. Do investigation to find the root case.
  4. Recovery such as reset passwords, activate patch system.
  5. Regulatory Reporting
     → In here, People's Bank confirm the Central Bank of Sri Lanka(CBSL) if it is required.

- **Intrusion Prevention System(IPS)**

  In here;

  → It block the confirmed malicious automatically.

  → Work together with WAF to stop the attacks in real time.

B7. Resilience and Reliability

- **High Availability**

  These controls make that the system is keep running even if the one part is failed.

  → The load balancer in the DMZ spread traffic so the servers got overload.

  → There are redundant app servers for if the one server crashers then can use another one.

  → Use database master replica for when one database writes, the replica stay ready for a failover.

  → Also, use Active passive DR sites as a backup site exists and can be activated during a major outage.

- **Failover strategy**

  In the use of this strategy, when a failure happens, system will switches to backups automatically.

  → App servers auto scale to start more servers automatically when the traffic is increases.

  → Database synchronous replication to copy real time data.

  → Core banking retry queues to wait and retry transactions if there was breakdown in core banking system.

  → Backup SMS gateway to send OTPs to another provider like email, if the SMS provider is failed.

  → Automatic Domain Name System(DNS) failover to move traffic to a clean site without interrupting the users.

- **Disaster Recovery(DR)**

  Use to recover the system even after a big incident.

  → RPO: Here, data losses up to 15 minutes are acceptable.

  → RTO: The full service should be restore within 1-2 hours.

  → Doing DR tests twice a year.

  → Keep encrypted offline backups for 6 months.

- **Performance and Rate Limiting**

  Limits number of login attempts like;

  → 5 login attempts per minute to prevent from brute force attacks.

  → 3 fund transfer attempts per minute.

  → API throttling per IP/device to prevent bots accesses and overloads.

B8. Compliance, Privacy and Audit

Compliance

The People's Bank Online Banking System follows the Sri Lankan banking law and international security standards.

- It mainly follows the CBSL guidelines which provide the Central bank security rules.
- Acts that on Sri Lankan Law related;
    - → Computer Cromes Act No.24 of 2007
    - → Electronic Transactions Act No.19 of 2006
    - → Evidence (Special provision) Act No.14 of 1995
    - → Payment Devices Fraud Act No.30 of 2006
    - → Payment and settlement System Act No.28 2005
    - → ICT (Information and communication Technology) Act No.27 of 2008

Privacy

- Only needed and minimum data collected. Do not store unnecessary data.
- Customer and other sensitive data is not share without consent.
- Not everyone can access the personal or sensitive data. And even access by specific officer it been recorded.

Audit

In here, the regular Audit keep the system secure, trustworthy. And also help to maintain the accountability. People's Bank held two types of Audit. They are;

1. Internal Audit
2. External Audit

- Scan the vulnerability quarterly like the system scan for it weak places every 3 months.
- Ethical hackers do a penetration test annually.
- Keep Audit logs for 7 years.
- Logs are cannot be edited or deleted so the audit storage is tamper proof.

B9. Traceability to SRS

SRS ID	Requirement	Implemented Controls
IAM-01	MFA for all users (customer and admin)	Customer user: • Password, OTP, Biometric for login
		Admin user: • MFA via VPN, TOTP • Device certificates
IAM-02	Role-based access	RBAC • Customer - Regular customer - Staff-Customer • Admin - System Admin - Fraud Analyst - Customer Support officer - Audit Officer
IAM-03	Session Management	• Auto logout after inactivation • Reject the reuse session tokens • Refresh token rotation • CSRF tokens • Suspicious activity invalidation
NET-01	Database must not expose to public	• Layer 3 firewall • No direct access from DMZ or the internet. • For admin, access only via approved VPN/IP
NET-02	WAF + Rate limit	• WAF in DMZ. • Rate limiting for attempts, transaction

		attempts and API requests. • Block SQLi and malicious payloads. • Endpoint segregation. • TLS everywhere enforced.
NET-03	Segmented network zones	• DMZ, Application, Database, Integration, Admin zones. • Layer 3 Firewall rules. • API Gateway enforcement.
SYS-01	Hardened servers	• CIS Benchmark hardened. • Only required services installed.
SYS-02	Monitoring and logging	• SIEM collects logs. • Monitoring dashboard for real time data. • Alerts on logins and failed logins • Alerts on file modification
APP-01	Input validation and output encoding	• OWASP Top 10 compliant. • Validate and sanitize inputs. • Parameterized queries. • Encode outputs. • SAST and DAST scannings.
APP-02	Secrets from secure vault	• All secrets in vault or in HSM. • Automatic rotation every 90 days. • Database credentials fetched at runtime. • TLS certificates managed.
DATA-01	Encryption at rest/in transit	• TDE. • Column-level encryption. • Masking. • Encrypted log volumes. • TLS 1.2+ for all communications. • Mutual TLS for admin/internal.

DATA-02	Key management/rotation	• Keys stored in HSM or vault. • Automatic rotation. • Separate keys for encryption/signing/TLS
DATA-03	Backups and restore testing	• Daily incremental and weekly full backups. • Offsite DR location. • Integrity checks with SHA-256. • Quarterly restore drills.

References

- (No date) *Loan service CIB/CMB user information manual corporate internet banking*. Available at: https://www.peoplesbank.lk/roastoth/2022/06/Loan_Service.pdf (Accessed: 03 December 2025).
- Chkadmin (2023) *Network security architecture*, *Check Point Software*. Available at: https://www.checkpoint.com/cyber-hub/network-security/what-is-network-security/network-security-architecture/ (Accessed: 02 December 2025).
- *How to draw 5 types of architectural diagrams* (2021) *Lucidchart*. Available at: https://www.lucidchart.com/blog/how-to-draw-architectural-diagrams (Accessed: 28 November 2025).
- *Online_banking* (2024a) *People's Bank*. Available at: https://www.peoplesbank.lk/online-banking/ (Accessed: 27 November 2025).